

SIMATS ENGINEERING

ASSESSMENT TOOL 1

**COURSE NAME: Ethical Hacking
ITA1401**

COURSE CODE:

COURSE OUTCOME COVERED

CO2: Foot printing Tools: Conducting Competitive Intelligence, DNS Zone Transfers, Introduction to Social Engineering: Social Engineering Attacks and Countermeasures. (BT3)

Assessment Tool Weightage: 30%

Duration: 90 min

Total Marks: 50

Report Analysis Questions

1. A security analyst performed a network scan on the target 192.168.1.10 using the Nmap tool. The report identified several open ports, including HTTP (80), SSH (22), and MySQL (3306), along with the operating system and service versions. Analyze the report and explain the security risks associated with the identified services. Discuss how an attacker could exploit these services and recommend suitable security measures to protect the target system. **(20 Marks)**
2. A phishing awareness campaign was conducted for employees of ABC Technologies Pvt. Ltd. using the GoPhish tool. The report indicates that 40% of employees clicked the phishing link, 20% entered their login credentials, and several users downloaded a malicious attachment. Analyze the report and identify the security weaknesses demonstrated by the employees. Recommend suitable user awareness programs, email security controls, and organizational policies to reduce the risk of successful social engineering attacks.**(20 Mark).**
3. A DNS assessment report generated using the Dig tool shows that the organization's DNS server permits a successful DNS Zone Transfer (AXFR), exposing internal hostnames, mail servers, and DNS records. Analyze the report and explain the security implications of the exposed information. Discuss how attackers could exploit these findings and recommend best practices to secure the DNS infrastructure..**(10 Marks)**

Code of Conduct:

I KALPANA J(192521038) (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

KALPANA J

1. NETWORK SCAN ANALYSIS USING NMAP

AIM

To analyze the results of a network scan performed using Nmap, identify the security risks associated with open ports and running services, explain potential attack risks, and recommend suitable security measures.

INTRODUCTION

Nmap (Network Mapper) is a network scanning and security auditing tool used to identify active hosts, open ports, running services, service versions, and operating-system information.

In this scenario, a security analyst scanned the authorized target system **192.168.1.10**. The scan identified several open services, including HTTP on port 80, SSH on port 22, and MySQL on port 3306. The operating system and service versions were also identified.

SCAN FINDINGS

Port	Service	Security Concern
22	SSH	Unauthorized login, brute-force attacks, weak credentials
80	HTTP	Web vulnerabilities, outdated software, information disclosure
3306	MySQL	Unauthorized database access, data exposure
OS/Service versions	System information	Helps attackers identify vulnerabilities

SECURITY RISKS

1. SSH – Port 22

SSH is used for secure remote administration. Although SSH provides encrypted communication, exposing it to an untrusted network can increase the attack surface.

Potential risks include:

- Brute-force login attempts.
- Password-based attacks.
- Exploitation of vulnerable SSH versions.
- Unauthorized remote access if credentials are compromised.
- Account enumeration and automated scanning.

An attacker who obtains valid SSH credentials could potentially gain remote access to the system.

2. HTTP – Port 80

Port 80 indicates that an HTTP web service is running.

Potential risks include:

- Vulnerable web applications.
- Outdated web-server software.
- Improper authentication.
- Insecure configuration.
- Information disclosure.
- Web application vulnerabilities such as injection or cross-site scripting.

If the web application contains vulnerabilities, an attacker could potentially use them to access unauthorized information or compromise the server.

3. MySQL – Port 3306

MySQL is a database management system. Exposing port 3306 to unnecessary networks creates a significant security risk.

Potential risks include:

- Unauthorized database connections.
- Weak or compromised database credentials.
- Exposure of sensitive information.
- Exploitation of vulnerable database software.
- Data modification or deletion.

If an attacker obtains database access, sensitive organizational information stored in the database could be compromised.

4. Operating System and Service Version Disclosure

The scan identified the operating system and service versions.

This information is useful to legitimate administrators but can also assist attackers in reconnaissance. Attackers can compare software versions with publicly known vulnerabilities and determine which attacks may be applicable.

HOW ATTACKERS COULD EXPLOIT THE FINDINGS

An attacker could first use the open ports and version information to understand the target's attack surface. They could then investigate known vulnerabilities affecting the detected services.

For example:

**Reconnaissance → Service identification → Vulnerability identification →
Exploitation attempt → Unauthorized access**

SSH could be targeted with credential attacks, the web server could be examined for application vulnerabilities, and MySQL could be targeted for unauthorized database access if it is unnecessarily exposed.

RECOMMENDED SECURITY MEASURES

1. Secure SSH

- Disable unnecessary SSH access.
- Use key-based authentication instead of passwords where possible.
- Disable direct root login.
- Use strong authentication mechanisms.
- Restrict SSH access to trusted IP addresses or VPN users.
- Keep SSH software updated.
- Implement account lockout/rate-limiting controls.

2. Secure HTTP

- Keep the web server and applications updated.

- Remove unnecessary services and applications.
- Use HTTPS/TLS instead of unencrypted HTTP.
- Apply secure authentication and authorization.
- Perform regular vulnerability assessments.
- Use a Web Application Firewall where appropriate.

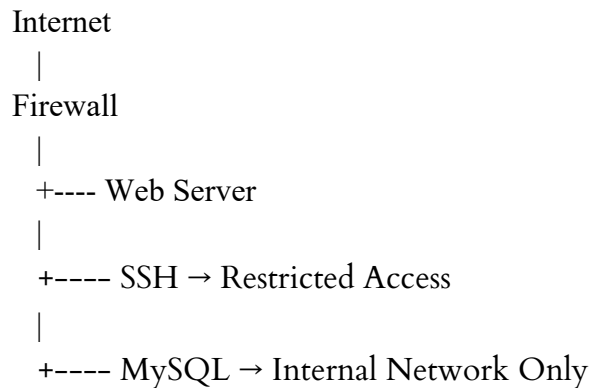
3. Secure MySQL

- Do not expose port 3306 directly to the public or untrusted network.
- Restrict database access using firewalls.
- Use strong and unique database credentials.
- Apply least-privilege permissions.
- Keep MySQL updated.
- Encrypt sensitive database connections where appropriate.
- Monitor database access and authentication attempts.

4. Network Security

A firewall should allow only required ports and trusted sources.

For example:



5. Patch Management

The operating system and all services should be regularly updated to address known security vulnerabilities.

CONCLUSION

The Nmap scan demonstrates that open ports increase the attack surface of a system. SSH, HTTP, and MySQL each provide legitimate functionality but can introduce security risks when improperly configured or exposed unnecessarily. Restricting network access, applying patches,

```
(kali㉿kali)-[~]
└─$ sudo nmap -A 192.168.1.10
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-01 05:13 EDT
Nmap scan report for 192.168.1.10
Host is up (0.0035s latency).
All 1000 scanned ports on 192.168.1.10 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Aggressive OS guesses: 3Com 4500G switch (92%), H3C Comware 5.20 (92%), Huawei VRP 8.100 (92%), Microsoft Windows Server 2003 SP1 (92%),
Camera (92%), D-Link DP-300U, DP-G310, or Hamlet HPS01UU print server (92%), HP Tru64 UNIX 5.1A (92%), Sanyo PLC-XU88 digital video pr
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

TRACEROUTE (using port 80/tcp)
HOP RTT ADDRESS
1 3.57 ms 192.168.1.10

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 15.69 seconds
```

[illegible]

```
kali@kali:~$ sudo nmap -sV -oN Assignment1_Nmap_Report.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-31 01:54 EDT
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.0028s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:9fff:fe18:bb2f
Not shown: 988 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
111/tcp   open  rpcbind
135/tcp   open  msrpc
139/tcp   open  smb
143/tcp   open  imap
161/tcp   open  snmp
443/tcp   open  https
8080/tcp  open  http-alt
8081/tcp  open  http-alt
8082/tcp  open  http-alt
Device type: bridge(usb adapter)general purpose
Running (JUST GUESSING): Oracle VirtualBox (94%), Slirp (94%), AT&T embedded (92%), QEMU (90%)
OS CPE: cpe:/o:oracle:virtualbox cpe:/a:danny.gasparovski:slirp cpe:/a:qemu:qemu
Aggressive OS guesses: Oracle VirtualBox Slirp NAT bridge (94%), AT&T ROM210 voice gateway (92%), QEMU user mode network gateway (90%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

TRACEROUTE (using port 80/tcp)
HOP RTT ADDRESS
1 1.77 ms scanme.nmap.org (45.33.32.156)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 94.05 seconds

kali@kali:~$
```

2. PHISHING AWARENESS CAMPAIGN USING GOPHISH

AIM

To analyze a phishing-awareness campaign conducted using GoPhish, identify security weaknesses demonstrated by employees, and recommend suitable user-awareness programs, email-security controls, and organizational policies.

INTRODUCTION

Phishing is a social-engineering attack in which attackers use deceptive emails, links, websites, or attachments to trick users into revealing sensitive information or performing unsafe actions.

GoPhish is a phishing simulation and security-awareness platform that can be used in an authorized environment to evaluate employee responses to simulated phishing attacks.

ABC Technologies Pvt. Ltd. conducted a phishing-awareness campaign and obtained the following results.

CAMPAIGN RESULTS

Employee Activity	Result
Clicked phishing link	40%

Entered login credentials	20%
Downloaded malicious attachment	Several users

ANALYSIS OF SECURITY WEAKNESSES

1. High Phishing Link Click Rate

40% of employees clicked the phishing link. This indicates that a significant number of employees may not be adequately checking email senders, URLs, or message content before clicking links.

2. Credential Disclosure

20% of employees entered their login credentials. This represents a serious security weakness because compromised credentials can potentially be used to access organizational accounts and resources.

3. Unsafe Attachment Handling

Several users downloaded a malicious attachment. This indicates inadequate awareness of the risks associated with unexpected email attachments.

4. Lack of Email Verification

Employees may be trusting emails without independently verifying the sender or the request.

5. Insufficient Security Awareness

The results demonstrate the need for continuous cybersecurity awareness training rather than relying only on technical security controls.

RECOMMENDED USER AWARENESS PROGRAMS

1. Phishing Awareness Training

Employees should be trained to identify:

- Suspicious sender addresses.

- Fake URLs.
- Urgent or threatening messages.
- Unexpected attachments.
- Requests for passwords or sensitive information.

2. Regular Phishing Simulations

Authorized phishing simulations should be conducted periodically to measure employee awareness and identify areas requiring additional training.

3. Security Workshops

Workshops should demonstrate common social-engineering techniques and explain how employees can verify suspicious requests.

4. Phishing Reporting

Employees should have an easy mechanism such as a **Report Phishing** button to report suspicious emails to the IT/security team.

EMAIL SECURITY CONTROLS

SPF, DKIM and DMARC

These email authentication mechanisms help protect the organization's domain from spoofing and unauthorized email use.

Email Filtering

Email security gateways should identify and block spam, phishing emails, suspicious links, and malicious content.

Attachment Scanning

Attachments should be scanned using antivirus and malware-analysis technologies.

URL Protection

Links in emails should be inspected for malicious or suspicious destinations.

Multi-Factor Authentication

MFA should be enabled for important accounts. Even if a password is compromised, MFA provides an additional security layer.

Endpoint Protection

Employee systems should have updated antivirus and endpoint-security solutions.

ORGANIZATIONAL POLICIES

- Employees should never share passwords through email.
- Suspicious requests should be independently verified.
- Suspicious emails should be reported immediately.
- Strong and unique passwords should be used.
- MFA should be mandatory for critical systems.
- Security awareness training should be conducted regularly.
- A documented phishing incident-response process should be maintained.
- Access to sensitive systems should follow the principle of least privilege.

CONCLUSION

The campaign demonstrates significant employee susceptibility to social-engineering attacks. The 40% click rate, 20% credential-submission rate, and malicious attachment downloads indicate weaknesses in phishing recognition and safe email handling.

ABC Technologies should use a defense-in-depth approach combining **security awareness training, phishing simulations, email filtering, SPF/DKIM/DMARC, URL and attachment protection, MFA, endpoint security, and clear organizational policies.**

gophish

DashboardCampaignsUsers & GroupsEmail TemplatesLanding PagesSending ProfilesSettingsadmin

Dashboard

Campaigns

Users & Groups

Email Templates

Landing Pages

Sending Profiles

Settings

User Guide

API Documentation

Users & Groups

+ New Group

Search:

Show 10 entries

Name	# of Members	Modified Date
ABC Technologies Awareness Lab	4	August 13th 2026, 8:51:27 am

Showing 1 to 1 of 1 entries

Previous1Next

gophish

DashboardCampaignsUsers & GroupsEmail TemplatesLanding PagesSending ProfilesSettingsadmin

Dashboard

Campaigns

Users & Groups

Email Templates

Landing Pages

Sending Profiles

Settings

User Guide

API Documentation

Email Templates

+ New Template

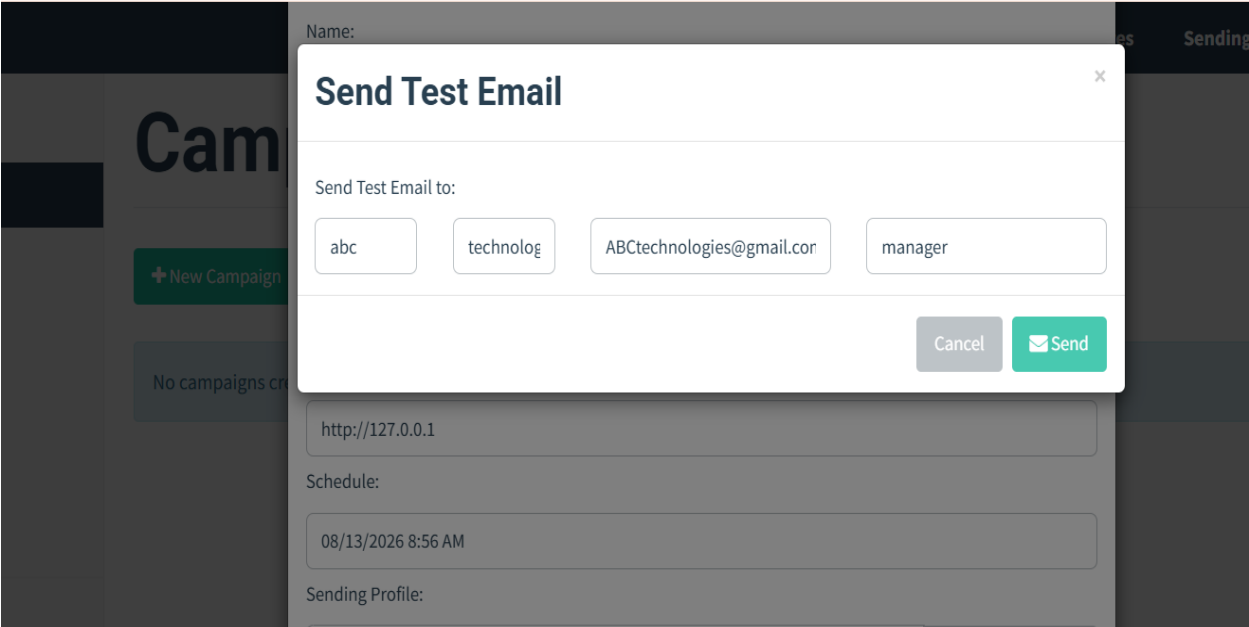
Search:

Show 10 entries

Name	Modified Date
ABCTechnologies@gmailcom	August 13th 2026, 8:53:56 am

Showing 1 to 1 of 1 entries

Previous1Next



3. DNS ZONE TRANSFER ANALYSIS USING DIG

AIM

To analyze the security implications of an unauthorized DNS Zone Transfer (AXFR), understand the information exposed by the DNS server, and recommend best practices for securing DNS infrastructure.

INTRODUCTION

The Domain Name System (DNS) translates domain names into IP addresses and provides other information required for network communication.

A DNS Zone Transfer, particularly an **AXFR (Authoritative Zone Transfer)**, is designed to allow DNS information to be replicated between authorized DNS servers. If an organization permits unrestricted zone transfers, unauthorized users may obtain detailed information about its DNS infrastructure.

FINDINGS

The DNS assessment showed that an unauthorized DNS Zone Transfer was successful.

The transfer exposed information including:

- Internal hostnames.
- Mail servers.
- IP addresses.
- DNS records.
- Subdomains.
- Nameserver information.

SECURITY IMPLICATIONS

1. Information Disclosure

A successful zone transfer provides attackers with a detailed map of the organization's DNS infrastructure.

2. Internal Hostname Exposure

Internal hostnames can reveal information about servers, applications, departments, or network infrastructure.

3. Mail Server Exposure

Mail-server records can help attackers identify systems involved in email communication and potentially target them for phishing, spoofing, or other attacks.

4. Easier Reconnaissance

Instead of discovering systems individually, an attacker can obtain many DNS records from a single successful zone transfer.

5. Target Identification

The exposed information can help attackers identify important systems that may require further security assessment.

HOW ATTACKERS COULD USE THE INFORMATION

An attacker could use the exposed DNS information to build an infrastructure map:

DNS Zone Transfer



Hostnames + IP Addresses



Identify Important Systems



Further Security Assessment



Potential Attack Targets

The zone-transfer information itself does not necessarily compromise a server, but it significantly reduces the effort required for reconnaissance and can increase the effectiveness of subsequent attacks.

RECOMMENDED SECURITY MEASURES

1. Restrict Zone Transfers

AXFR should be permitted only between authorized DNS servers.

2. Use Access Control

Configure DNS servers to allow zone transfers only from trusted secondary DNS servers.

3. Use TSIG Authentication

Transaction Signatures (TSIG) can be used to authenticate authorized DNS zone-transfer requests.

4. Separate Internal and External DNS

Internal DNS information should not be unnecessarily exposed to the public internet.

5. Minimize Information Disclosure

Avoid unnecessarily exposing sensitive internal hostnames and infrastructure information through public DNS.

6. Monitor DNS Activity

DNS logs should be monitored for unusual zone-transfer requests and other suspicious activities.

7. Regular Security Testing

Organizations should periodically test DNS configurations to verify that unauthorized zone transfers are not permitted.

CONCLUSION

An unrestricted DNS Zone Transfer represents a significant information-disclosure vulnerability. Although it may not directly compromise a server, the exposed hostnames, mail servers, IP addresses, and DNS records can provide attackers with valuable reconnaissance information. The organization should restrict AXFR requests to authorized DNS servers, use appropriate authentication such as TSIG, separate internal and external DNS infrastructure, monitor DNS activity, and regularly audit DNS configurations.

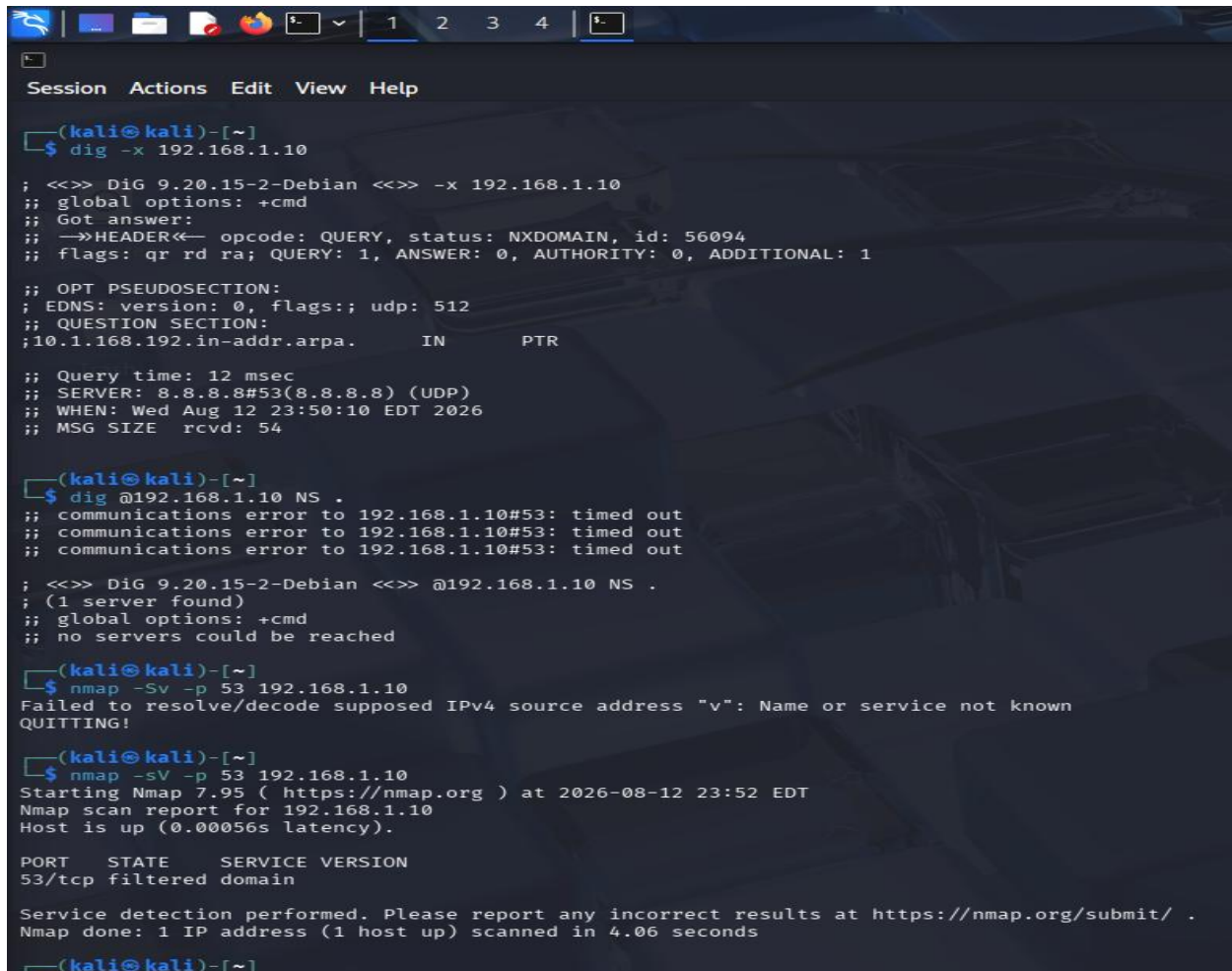
The three assessments demonstrate different stages of cybersecurity risk:

Nmap identifies exposed network services, **GoPhish** evaluates human susceptibility to social engineering, and **Dig** identifies information leakage through DNS configuration.

Effective security therefore requires a layered approach:

Secure Network Services + Train Users + Secure DNS + Monitor Continuously

Organizations should regularly perform vulnerability assessments, conduct security-awareness programs, implement strong access controls, maintain updated software, and continuously monitor their infrastructure to reduce the overall attack surface.



```
(kali@kali)~$ dig -x 192.168.1.10

; <<>> DiG 9.20.15-2-Debian <<>> -x 192.168.1.10
;; global options: +cmd
;; Got answer:
;; -->HEADER<-- opcode: QUERY, status: NXDOMAIN, id: 56094
;; flags: qr rd ra; QUERY: 1, ANSWER: 0, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 512
;; QUESTION SECTION:
;10.1.168.192.in-addr.arpa.      IN      PTR

;; Query time: 12 msec
;; SERVER: 8.8.8.8#53(8.8.8.8) (UDP)
;; WHEN: Wed Aug 12 23:50:10 EDT 2026
;; MSG SIZE rcvd: 54

(kali@kali)~$ dig @192.168.1.10 NS .
;; communications error to 192.168.1.10#53: timed out
;; communications error to 192.168.1.10#53: timed out
;; communications error to 192.168.1.10#53: timed out

; <<>> DiG 9.20.15-2-Debian <<>> @192.168.1.10 NS .
; (1 server found)
;; global options: +cmd
;; no servers could be reached

(kali@kali)~$ nmap -Sv -p 53 192.168.1.10
Failed to resolve/decode supposed IPv4 source address "v": Name or service not known
QUITTING!

(kali@kali)~$ nmap -sV -p 53 192.168.1.10
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-12 23:52 EDT
Nmap scan report for 192.168.1.10
Host is up (0.00056s latency).

PORT      STATE      SERVICE VERSION
53/tcp    filtered  domain

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 4.06 seconds

(kali@kali)~$
```

```
Session Actions Edit View Help

(kali@kali)-[~]
$ dig -x 192.168.1.10
; <<>> DiG 9.20.15-2-Debian <<>> -x 192.168.1.10
;; global options: +cmd
;; Got answer:
;; -->HEADER<-- opcode: QUERY, status: NXDOMAIN, id: 56094
;; flags: qr rd ra; QUERY: 1, ANSWER: 0, AUTHORITY: 0, ADDITIONAL: 1
;; OPT PSEUDOSECTION:
;; EDNS: version: 0, flags:; udp: 512
;; QUESTION SECTION:
;10.1.168.192.in-addr.arpa.      IN      PTR

;; Query time: 12 msec
;; SERVER: 8.8.8.8#53(8.8.8.8) (UDP)
;; WHEN: Wed Aug 12 23:50:10 EDT 2026
;; MSG SIZE rcvd: 54

(kali@kali)-[~]
$ dig @192.168.1.10 NS .
;; communications error to 192.168.1.10#53: timed out
;; communications error to 192.168.1.10#53: timed out
;; communications error to 192.168.1.10#53: timed out
; <<>> DiG 9.20.15-2-Debian <<>> @192.168.1.10 NS .
; (1 server found)
;; global options: +cmd
;; no servers could be reached

(kali@kali)-[~]
$ nmap -Sv -p 53 192.168.1.10
Failed to resolve/decode supposed IPv4 source address "v": Name or service not known
QUITTING!

(kali@kali)-[~]
$ nmap -sV -p 53 192.168.1.10
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-12 23:52 EDT
Nmap scan report for 192.168.1.10
Host is up (0.00056s latency).

PORT      STATE      SERVICE VERSION
53/tcp    filtered  domain

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 4.06 seconds

(kali@kali)-[~]
```

```
Session Actions Edit View Help

(kali@kali)-[~]
$ nmap -Sv -p 53 192.168.1.10
Failed to resolve/decode supposed IPv4 source address "v": Name or service not known
QUITTING!

(kali@kali)-[~]
$ nmap -sV -p 53 192.168.1.10
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-12 23:52 EDT
Nmap scan report for 192.168.1.10
Host is up (0.00056s latency).

PORT      STATE      SERVICE VERSION
53/tcp    filtered  domain

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 4.06 seconds

(kali@kali)-[~]
$ ping -c 4 192.168.1.10
PING 192.168.1.10 (192.168.1.10) 56(84) bytes of data.

— 192.168.1.10 ping statistics —
4 packets transmitted, 0 received, 100% packet loss, time 3050ms

(kali@kali)-[~]
$ nmap -p 52 192.168.1.10
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-12 23:54 EDT
Nmap scan report for 192.168.1.10
Host is up (0.00075s latency).

PORT      STATE      SERVICE
52/tcp    filtered  xns-time

Nmap done: 1 IP address (1 host up) scanned in 0.34 seconds

(kali@kali)-[~]
$ nmap -sV -p 53 192.168.1.10
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-12 23:55 EDT
Nmap scan report for 192.168.1.10
Host is up (0.0038s latency).

PORT      STATE      SERVICE VERSION
53/tcp    filtered  domain

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.09 seconds

(kali@kali)-[~]
```

RUBRICS FOR CALCULATION

Report Analysis

Criteria	Weightage (%)	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Report Analysis and Interpretation	25%	Accurately interprets the security report, identifies all key findings, and explains their significance with excellent technical understanding.	Correctly interprets most findings with minor omissions or inaccuracies.	Identifies only some findings and provides limited interpretation.	Unable to interpret the report or identify key findings.
Identification of Security Risks and Vulnerabilities	25%	Correctly identifies all security risks, vulnerabilities, and possible attack vectors with clear technical justification.	Identifies most risks and vulnerabilities with minor errors.	Identifies only a few risks with limited technical explanation.	Fails to identify major risks or vulnerabilities.
Application of Cybersecurity Concepts and Countermeasures	30%	Applies appropriate ethical hacking concepts and recommends comprehensive, practical, and technically sound countermeasures.	Recommends suitable countermeasures with minor technical gaps.	Provides limited or partially appropriate recommendations.	Recommendations are inappropriate, incomplete, or missing.
Technical Communication and Documentation	20%	Response is well-organized, technically accurate, clearly presented, and uses appropriate cybersecurity terminology throughout.	Response is organized and understandable with minor documentation or presentation issues.	Response lacks clarity, organization, or contains several technical inaccuracies.	Response is poorly organized, incomplete, and difficult to understand.

